Fase 1

1. *Godt jobbet med å skaffe deg tilgang til 9. Men dette var ikke spesielt vanskelig for den sleipe, sjarmerende hackeren du er. (...) Gardesjefen i Huseby militærleir i Oslo. Beskriv kort, noen få setninger, hvordan du ville gått frem for å få tak i minnepinnen*.

Jeg ville anntatt at det svakeste leddet ved Huseby militærleir fortsatt er den menneskelige faktoren, men det er vanskelig å si uten å observere leiren. Å snike seg inn bak noen andre som skal inn i leiren ville trolig ikke holdt, da man kan forvente strengere rutiner rundt ID-sjekk. Derfor ville det første steget vært å overvåke området og forsøke å kartlegge rutiner og sårbarheter. For eksempel kan man se etter travle øyeblik slik som skiftbytte, der man i en passende forkledning kan greie å snike seg inn. Eventuelt kan man forsøke å overbevise én eller et par ferske ansatte om at du hører hjemme i leiren, slik at det ikke stilles spørsmål når man forsøker å ta seg inn i leiren. Avhengig av sikkerhetsrutinene ved Huseby militærleir kan det godt tenkes at det er lettere enn en skulle tro å få noen andre til å slippe deg inn.

2. Skadevaren vi har lagd for dette angrepet er et lite teknisk mirakel. Men har du forstått hva det gjør? Forklar kort funksjonaliteten til skadevaren.

'Skadevaren' er en ELF fil som kan kjøres med diverse argumenter. Avhengig av argumentene oppgitt av brukeren vil programmet kjøre forskjellige sekvenser. Hvis antall argumenter er 0 (argc == 1), vil programmet kun printe "Hei, verden". Utover dette har programmet to modus basert på første argument.

Hvis første argument er "xor", men det ikke oppgis ytterligere 2 argumenter vil programmet printe ("Usage: <mode> <enc.string> <key>") – noe som forteller brukeren hvordan de skal bruke programmet. Men hvis brukeren oppgir tre argumenter som passer, vil programmet printe en streng kryptert ved hjelp av en xor-funksjon. Deretter avslutter programmet.

Hvis første argument er "exec" blir brukeren tatt gjennom et slags tekst-eventyr som simulerer en hacking-liknende sekvens. Ved å velge riktig port (19) og riktig "gjemmested" ("CPU"), vil brukeren bli møtt med suksess-meldinger, og ellers beskjed om at oppdraget mislyktes. Deretter avslutter programmet.

3. Hva er det dekrypterte innholdet i "tullehund"? Hvor fant du dette? Hva forteller det deg om tullehund at du fant den der?

Det dekrypterte innholdet i "tullehund" er shorturl.at/sbrYn

Lokasjonen til tullehund lå like ved en variabel kalt "secret" og "not_the_key", noe som var et hint om at dette var "målet for angrepet". Ved å åpne cutepuppy.jpeg og cutekitten.jpeg kunne man finne en tilsvarende kryptert streng med en variabel "not_the_key" med tre binærtall. Ved å gjøre en NOT-operasjon på denne fikk man den riktige nøkkelen for å dekryptere strengen til en mer lesbar hex – som så kunne konverteres til en lesbar URL.

4. Du har fått .jpeg-filer som lover å være bilder av søte hunder og pusekatter. Klarer du å se på bildene? Hvorfor/hvorfor ikke?

Bildene kan ikke åpnes ettersom de ikke er jpeg-filer, men er ELF filer med .jpeg som navn-endelse. Det eksisterer ikke noe bilde i filen som kan vises på skjermen, og datamaskinen vil ikke prøve å gjøre det heller – kun gi en feilmedling.

5. Cyanpilled.no er en litt sårbar nettside. Hvordan ville du gått frem for å ødelegge for alle andre og knekke siden? (Ikke gjør det, det er ulovlig og vi annser det som høyforæderi)

Cyanpilled.no sender automatisk en epost til alle som melder seg på, og har ingen sperrer for gjentatte påmeldinger eller ugyldige påmeldinger. Dermed ville et tjenestenektangrep – det vil si å bruke programvare til å kjøre ekstreme mengder påmeldinger på en gang - trolig være lett å utføre og sperre nettsiden for alle som ønsker å bruke den.

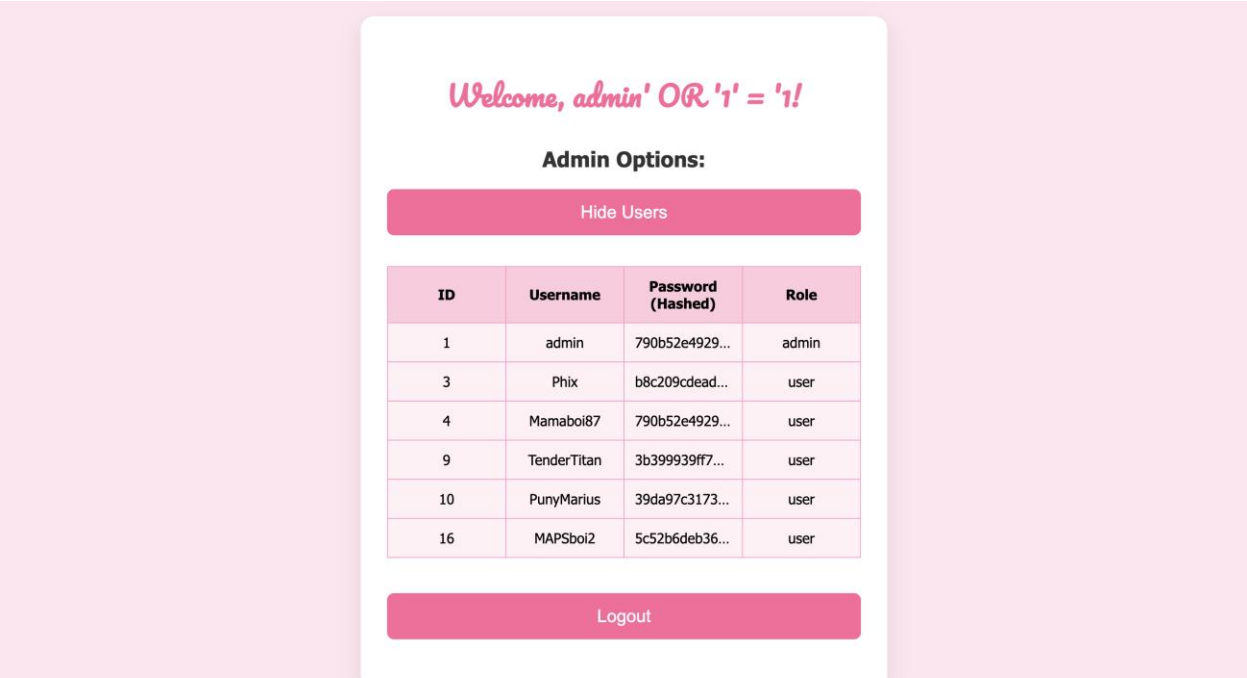
Fase 2

Spørsmål:

1. Hvilken angrepsmetodikk brukte du for å få tilgang til admin-brukeren? Hvordan kan du beskytte en nettside mot dette? Legg ved et screenshot av listen du får med passord.

For å få tilgang til admin-brukeren brukte jeg følgende SQL-injeksjon i brukernavnfeltet:

admin' OR '1' = '1



ID	Username	Password (Hashed)	Role
1	admin	790b52e4929...	admin
3	Phix	b8c209cdead...	user
4	Mamaboi87	790b52e4929...	user
9	TenderTitan	3b399939ff7...	user
10	PunyMarius	39da97c3173...	user
16	MAPSboi2	5c52b6deb36...	user

Det finnes mange måter man kan beskytte nettsiden mot et slikt angrep. Det vi har nevnt i in2120 er at man må sørge for å validere alle brukerinput. Whitelisting innebærer at man kun aksepterer input med en gitt lengde, i et gitt format, med symboler av en bestemt type – og er god måte å validere brukerinput. (Det kan nevnes at dette foretrekkes over blacklisting siden det er vanskelig å blackliste alle sårbarheter enn å whiteliste det man vet skaper få problemer) Det er også viktig å unngå at SQL-spørringer bruker brukerinput direkte – men at brukerinput kun behandles som data.

2. Hva er det ikke-hashede passordet til Mamaboi87? Hvordan fant du det?

Passordet til Mamaboi87 er 'C00kie?' Jeg fant det ved å bruke john the ripper med følgende kommando

```
john --wordlist=rockyou.txt --format=Raw-SHA256 --rules=Single mamaboy.txt
```

Hvor mamaboy.txt kun inneholder det hashede passordet til mamaboy.

3. John the Ripper kan brukes til å knekke hasher. Hva betyr det å kjøre programmet med "rules". Hva gjør "rules"?

Å knekke en hash ved hjelp av brute-force eller inkrementering tar ekstremt lang tid. Rules gir bestemte instrukser til hva slags behandling av passord som skal forsøkes først, for å øke sjansen for å finne et treff på kortere tid. For eksempel kan man ha en regel om å legge til tallsekvenser som 123 etter hvert ord som forsøkes, eller å erstatte bokstaver med tall, i.e. mittpassord => m1ttp4ss0rd.

4. Hvilken form for phishing utførte du som en del av dette oppdraget? Nevn noen andre varianter også. Legg ved et screenshot av phishing-eposten din.

Jeg utførte spyd-phishing ved å ha et spesifikt mål basert på spesifikk informasjon som kun gjelder brukeren som mottok angrepet. Den er personalisert for å ha høyere treffsikkerhet på én bestemt person. Andre typer phishing er masse-phishing som sendes til mange i håp om at noen biter på, hval-phishing som har toppledere og andre sentrale figurer som mål, eller klone-phishing som bruker kopier av vanlige eposter og erstatter vedlegg eller lenker med skadelig innhold.

(Siden det er et rollespill lagde jeg ikke en egen epost for 'phishing forsøket', håper det går greit 😅)

5. Er dette angrepsscenarioet lovlig? Anta at alt er ekte, hostet online og det faktisk var fra gardesjefen sitt kontor du hentet malwaren. Hva av det du har gjort er lov og hva er ulovlig?

Følgende aktiviteter er lovlig:

- Undersøke malware vha. en IDE. (Men merk at malwaren ikke ble anskaffet ved lovlige midler)

- Kjøre en nedlastet nettside i en Docker (gitt at den er hentet ved lovlige midler), og analysere innholdet.

Følgende aktiviteter er ikke lovlig:

- Knekking av passord uten tillatelse til å gjøre dette er ulovlig – i henhold til straffeloven § 204 er det ulovlig å bryte en beskyttelse, og § 205 å skaffe tilgang til informasjon ved å bryte en beskyttelse.
- Å lese noens private dagbok vha. uautorisert tilgang er trolig krenkelse av en annen persons privatliv, jf. straffeloven § 267
- Uautorisert ferdsel på militær eiendom er høyst ulovlig, og tyveri av en USB-brikke.
- Phishing – forsøk på å tilegne personlige eller sensitive opplysninger (spesielt bankinformasjon) er ulovlig iht. straffeloven kapittel 30 (bedrageri).